

DOKUMEN THREAT MODELING & VULNERABILITY ASSESSMENT

Sistem Informasi Lost & Found IPB

Mata Kuliah : Keamanan Informasi (KOM1315)

Semester : Genap 2025/2026

Program Studi: Ilmu Komputer, IPB University

Dokumen : Hasil Vulnerability Assessment Awal (Tahap 1)

Kelompok 2 :

- Syafiq Syadidul Azmi (G6401231075)
- Muhammad Faqih (G6401231081)
- Luqman Fadillah Santoso (G6401231136)

1. Pendahuluan

Dokumen ini menyajikan hasil pemodelan ancaman (*Threat Modeling*) dan penilaian kerentanan (*Vulnerability Assessment*) awal terhadap sistem Lost & Found IPB. Analisis ini dilakukan untuk mengidentifikasi potensi celah keamanan sebelum sistem di-deploy ke lingkungan produksi, memastikan bahwa prinsip *Confidentiality*, *Integrity*, dan *Availability* (CIA Triad) terpenuhi.

2. Metodologi Analisis

Tim menggunakan dua kerangka kerja utama:

1. **STRIDE**: Digunakan untuk mengkategorikan jenis ancaman pada setiap aliran data.
2. **DREAD**: Digunakan untuk menghitung skor risiko (1-10) berdasarkan tingkat kerusakan, kemudahan eksploitasi, dan jumlah pengguna yang terdampak.

3. Identifikasi Titik Masuk (Entry Points)

EP-01	Endpoint <code>/token</code> (Login)	HTTP/POST
EP-02	Endpoint <code>/users/</code> (Registrasi)	HTTP/POST
EP-03	Endpoint <code>/items/report-*</code> (Upload Laporan)	HTTP/POST (Multipart)
EP-04	Endpoint <code>/claims/</code> (Upload Bukti Klaim)	HTTP/POST (Multipart)
EP-05	Akses Statis <code>/storage/</code>	HTTP/GET

4. Analisis Ancaman STRIDE

4.1 Spoofing (Penyamaran Identitas)

- **Ancaman:** Penyerang menggunakan kredensial curian atau memalsukan JWT untuk bertindak sebagai pengguna lain atau admin.
- **Risiko:** Tinggi (DREAD: 8/10).
- **Mitigasi Saat Ini:** JWT HS256 dengan Secret Key yang kuat dan hashing Argon2id.

4.2 Tampering (Manipulasi Data)

- **Ancaman:** Modifikasi data laporan barang atau status klaim saat transit atau di database.
- **Risiko:** Sedang (DREAD: 6/10).
- **Mitigasi Saat Ini:** Validasi skema Pydantic dan penggunaan SQLAlchemy ORM untuk mencegah SQL Injection.

4.3 Repudiation (Penyangkalan)

- **Ancaman:** Pengguna menyangkal telah melaporkan barang palsu atau admin menyangkal telah menyetujui klaim yang salah.
- **Risiko:** Sedang (DREAD: 5/10).
- **Status:** BELUM TERMITIGASI PENUH (Memerlukan Digital Signature/Non-repudiation).

4.4 Information Disclosure (Kebocoran Informasi)

- **Ancaman:** Akses tidak sah ke file foto bukti klaim yang bersifat sensitif atau data profil civitas.
- **Risiko:** Tinggi (DREAD: 9/10).
- **Mitigasi Saat Ini:** RBAC untuk endpoint API, namun direktori `/storage/` masih dapat diakses publik melalui URL langsung.

4.5 Denial of Service (DoS)

- **Ancaman:** Membanjiri server dengan request upload file besar untuk menghabiskan *disk space* atau CPU.
- **Risiko:** Sedang (DREAD: 6/10).
- **Status:** KERENTANAN TERIDENTIFIKASI (Belum ada Rate Limiting).

4.6 Elevation of Privilege (Peningkatan Hak Akses)

- **Ancaman:** Pengguna `UMUM` memodifikasi request untuk mengakses fungsi `ADMIN` (misal: `/claims/{id}/review`).
- **Risiko:** Sangat Tinggi (DREAD: 10/10).
- **Mitigasi Saat Ini:** Pengecekan peran `current_user.role == Role.ADMIN` di level router.

5. Hasil Vulnerability Assessment Awal

Berdasarkan tinjauan kode pada *Source Code* Tahap 1, berikut adalah temuan kerentanan awal:

VA-01	Unprotected Static Storage	File di <code>/storage/claims/</code> dan <code>/storage/items/</code> dapat diakses langsung oleh siapa saja yang mengetahui URL-nya tanpa pengecekan token.	Tinggi (Kebocoran Data Pribadi)	Gunakan middleware untuk memverifikasi JWT sebelum menyajikan file statis atau simpan file di luar <i>web root</i> .

VA-02	Lack of Rate Limiting	Tidak ada batasan jumlah request per IP, terutama pada endpoint login dan upload.	Sedang (Brute Force & DoS)	Implementasikan <code>slowapi</code> atau rate limiter pada level reverse proxy (Nginx).
VA-03	Missing Audit Trail	Aktivitas kritikal seperti penghapusan user atau persetujuan klaim tidak dicatat secara permanen di log database.	Sedang (Ketiadaan Akuntabilitas)	Implementasikan modul <i>Accounting</i> (AAA) untuk mencatat log aktivitas admin.
VA-04	JWT Secret Key Exposure Risk	Meskipun menggunakan <code>.env</code> , ketiadaan mekanisme <i>key rotation</i> meningkatkan risiko jika <i>Secret Key</i> terkompromi.	Tinggi (System-wide Breach)	Terapkan prosedur rotasi kunci secara berkala dan gunakan kunci asimetrik (RS256).
VA-05	Weak File Validation	Validasi file upload saat ini hanya berdasarkan ekstensi yang diberikan oleh client, bukan berdasarkan <i>magic bytes</i> (MIME type sesungguhnya).	Sedang (Malware Upload)	Tambahkan pustaka <code>python-magic</code> untuk memverifikasi tipe konten file yang diunggah.

6. Rencana Aksi Perbaikan (Roadmap Keamanan)

- Jangka Pendek (P8):** Menambahkan validasi tipe file yang lebih ketat dan implementasi rate limiting dasar pada endpoint `/token`.
- Jangka Menengah (P9-P10):** Migrasi ke JWT Asimetrik (RS256) dan implementasi tanda tangan digital untuk mencegah *Repudiation*.
- Jangka Panjang (P11-P12):** Implementasi modul logging AAA untuk akuntabilitas penuh dan pengamanan akses direktori `/storage`.

Dokumen ini merupakan hasil analisis internal Kelompok 2 untuk memenuhi standar keamanan sistem *Lost & Found IPB*.